

Threat Modeling

CS 465 · Introduction to Security and Privacy · Fall 2026

BYU



Fundamental Goals of Security

Ultimate goal: help users complete the task they wanted to do, safely — with no short- or long-term risk

The CIA triad

Confidentiality — secrets stay secret

Integrity — nothing changes without permission

Availability — the system is there when it is needed

AAA security

Authentication — prove who you are

Authorization — what you are allowed to do

Accounting — a record of what was actually done

Security Analysis

Open-ended work: find the vulnerabilities, then design the defenses



Not a phase — a habit

Security analysis runs the whole length of the software lifecycle. A formal review once the product is built, or a pen test once it is deployed, are checkpoints — not substitutes for thinking about it from the start.

What Is a Threat Model?

THE BOOK

A threat model identifies the threats, threat agents, and attack vectors that the target system considers in scope to defend against.

THREAT MODELING MANIFESTO

Analyzing representations of a system to highlight concerns about security and privacy characteristics.

OWASP

Identify, communicate, and understand threats and mitigations in the context of protecting something of value.

Notice the focus on threats. OWASP includes mitigations. But all these definitions are all too narrow.

The Four Questions from the Threat Modeling Manifesto

1 What are we working on?

Draw the system. Where does information live, who reaches it, how does control flow?

2 What can go wrong?

Model the adversaries, then enumerate attacks — taxonomies, STRIDE, card games.

3 What do we do about it?

Turn each threat into an action item somebody owns and can close.

4 Did we do well enough?

Measure, log, revisit — and bring in outside eyes.

What Goes Into a Threat Model

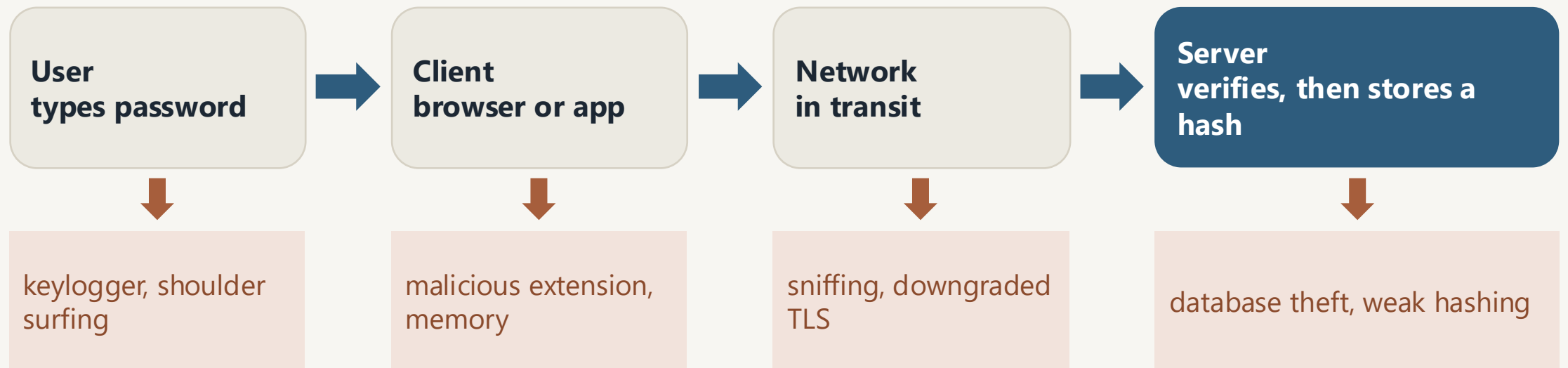
The subject	A description of exactly what is being modeled
The assumptions	Written down so they can be checked and challenged as the landscape shifts
The threats	What could plausibly be done to this system, and by whom
The mitigations	An action for each threat worth acting on
The validation	A way to check the model itself, and to verify the actions worked

Open-ended by nature — a long list of questions, and a lot of redrawing and reconsidering.

Q1 • What Are We Working On?

Draw the system: where information lives, who is granted access to it, and how control flows.

Example: where does a typed password actually go?



Every hop is a place information rests or moves — and every one of those places is a candidate for the threat list.

Q2 · Modeling the Adversary

Four questions to ask about anyone who might come for the system:

Who are they?

Objectives

Methods

Capabilities

Who shows up in practice

Foreign intelligence · cyber terrorists
Industrial spies · organized crime
Crackers · malicious insiders
The employee who clicks the wrong link

Tools

Attack taxonomies, and card games built for exactly this: Elevation of Privilege, OWASP Cornucopia, and the Security Cards deck.

STRIDE

S	Spoofing	Impersonating a person, a service, or a machine
T	Tampering	Altering code, data, or packets without permission
R	Repudiation	Denying responsibility for something you did
I	Information disclosure	Releasing data to someone who should not have it
D	Denial of service	Making the system unavailable to the people who need it
E	Elevation of privilege	Gaining access to resources you were never granted

A checklist for the second question — walk each hop of the diagram through all six.

Q3 and Q4 • Act, Then Check

What do we do about it?

the output of the exercise

Every threat worth acting on becomes an action item — a ticket with an owner and a due date.

Threats need to show up on a ticket list to have any change on the system.

Did we do well enough?

the long game

Metrics, logging, and measurement: are the threats you anticipated actually being stopped? Are new ones showing up?

Bring in outside eyes — consultants and pen testers see what the team overlooked.

What the Manifesto Values

A culture of finding and fixing design issues

over

checkbox compliance

People and collaboration

over

processes, methodologies, and tools

A journey of understanding

over

a security or privacy snapshot

Doing threat modeling

over

talking about it

Continuous refinement

over

a single delivery

Threat Modeling Manifesto · threatmodelingmanifesto.org

Gaps in a Threat Model

Invalid assumptions

The model rests on beliefs about the system that were never checked

Unanticipated threats

You cannot enumerate what you have not imagined

A stale model

Adversaries, technology, and the system all move after you stop looking

THE HOTEL SAFE

You choose your own combination, lock your money in the room safe, and go swimming. Three wrong guesses and it locks out.

So the money is safe — unless you ask who else can open it. Someone in maintenance holds a master code. A different face is behind the desk each day. If the money is gone, will the staff help you investigate? Will management? Are the local police related to the owner?

The lock was never the weak part. The assumptions around it were.



Your Turn: Threat Model a Car

THE SYSTEM

A modern automobile that runs a sophisticated software system controlling every aspect of the car.

Attackers

Who would come for this car, what do they want, and what can they actually do?

Threats

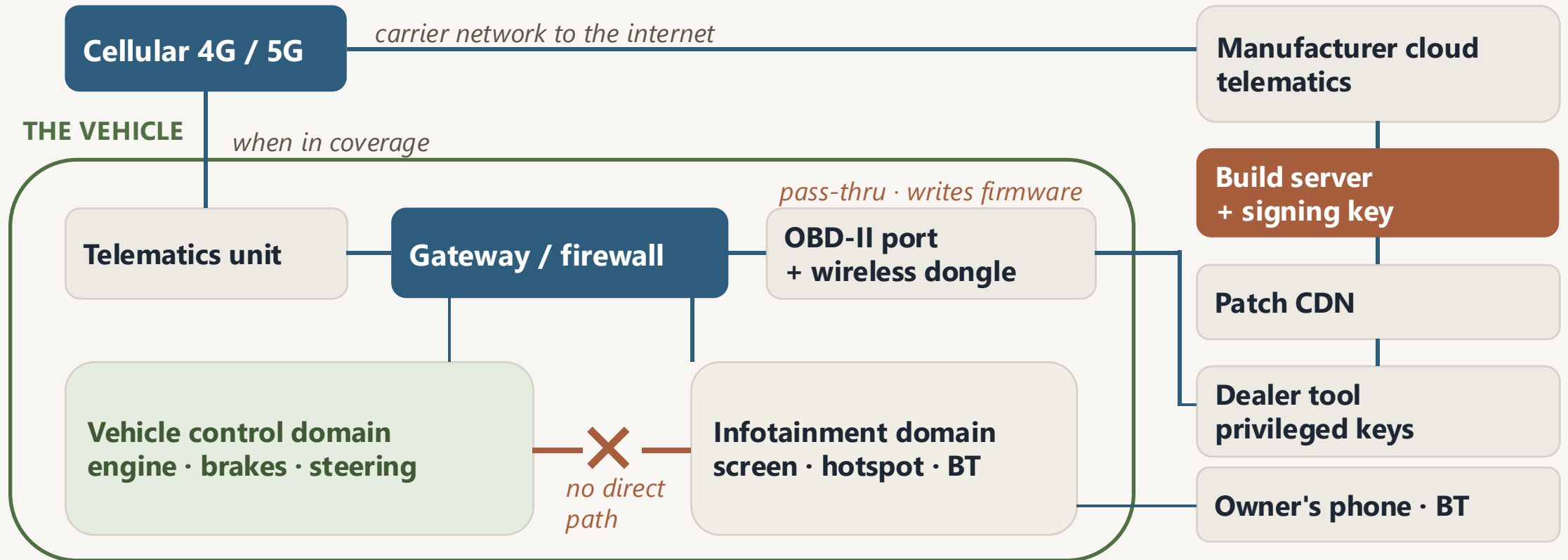
Walk the system with STRIDE — sensors, satellite link, patch pipeline.

Mitigations

For each threat worth acting on, what mitigation would you build?

Groups of 3 to 4 · 10 minutes to consider threats and countermeasures · then we compare

The Connected Car · System Sketch



Every remote path lands on the telematics unit and must cross the gateway — and the gateway is software.